

09.05.2024

Sanctions for Violating GDPR

The National Authority for the Supervision of Personal Data Processing has completed two investigations into two operators and has found violations of the provisions of Article 32 paragraph (1) letter b) and Article 32 paragraphs (2) and (4) of Regulation (EU) 2016/679.

Thus:

1. The operator MEDICOVER SRL was sanctioned with an administrative fine of 4,970.30 lei (equivalent to 1,000 EURO). The investigation was initiated following the operator's notification of a personal data security breach. The data security breach occurred as a result of the unauthorized disclosure of personal data from a medical consultation report to another patient for whom it was not intended. During the investigation, it was found that the operator did not take measures to ensure that any natural person acting under its authority and having access to personal data only processes them at the request of the operator and did not implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing, including the ability to ensure the confidentiality and integrity of processing systems and services. As such, this situation led to the loss of confidentiality of the processed personal data, through unauthorized disclosure and unauthorized access to personal data (such as: name, surname, date of birth, age, reason for the visit, personal pathological history, diagnosis, conclusions and recommendations, prescribed medication, hospitalization, referrals for tests/consultations) of a patient, by handing over the medical consultation report to another patient.

2. The operator IRIDEX GROUP SALUBRIZARE SRL was sanctioned with an administrative fine of 9,951.80 lei (equivalent to 2,000 EURO). The investigation was initiated following a complaint received from a natural person. The data security breach occurred as a result of sending a collective electronic message to the email addresses of the company's clients, addresses that were visible to all. During the investigation, it was revealed that the operator did not take measures to ensure that any natural person acting under its authority and having access to personal data only processes them at its request, and did not implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing, including the ability to ensure the confidentiality, integrity, availability, and continuous resilience of processing systems and services.

Legal and Communication Department
A.N.S.P.D.C.P